Activity 4 Report: Database Users, Roles, Privileges and Access Control

COMP 018 Database Administration | Project tested: BoardTrack (Boarding House and Rental Management) (Node.js + PostgreSQL) | Date of testing: 6 November 2026

1. Cover and links

Item	Value
Testing group	G08: Borreta, Joshua; Bola, Martin Lawrence; Juatchon, Joaquin Phillip; Marcos, Karl Raphael; Pacheco Jr., Sancho; Vera Cruz, Euan Joseph
Project tested	BoardTrack (Boarding House and Rental Management)
Owning group	Group 11 (BoardTrack)
Repository	https://github.com/karlrobertc-art/BoardTrack
Tracker	https://github.com/EclipseChan/bwisIT-Solutions---Campus-Canteen-Pre-Order-and-Queue-Management-System/tree/main/other_group_tests
Evidence files	a4_access_tests.txt, a3_deploy.txt, a3_app.txt

2. Access-control plan (from the project docs)

The repository has no SQL script for database roles. docs/user-roles.md describes three application roles (administrator, staff, tenant), enforced by a permission table in src/auth.js, and a plan for database roles: boardtrack_owner, boardtrack_admin_grp, app_runtime_grp, app_readonly_grp and a login role boardtrack_app. The document says these are for Activity 4 and shows a short sketch. The app connects with one account taken from DATABASE_URL.

3. Application roles tested over HTTP

User	Test	Expected	Actual
landlord	Create, edit and delete a property	Allowed	Allowed (HTTP 302 each)
caretaker	Read properties, rooms, tenants, leases, payments, bills	Allowed	Allowed (HTTP 200)
caretaker	Create, edit or delete a property	Denied	Denied (HTTP 403)
caretaker	Create or delete a room	Denied	Denied (HTTP 403)
caretaker	Add a tenant	Allowed	Allowed (HTTP 200)
caretaker	Delete a tenant, lease or payment	Denied	Denied (HTTP 403 each)
juan (tenant)	Open properties, rooms, tenants	Denied	Denied (HTTP 403 each)
juan (tenant)	List leases, payments, bills	Own rows only	Own rows only: 1 of 4 leases, 4 of 7 payments, 2 of 4 bills (matches the database counts)
juan (tenant)	Add a lease or payment, delete or edit another tenant's lease	Denied	Denied (HTTP 403 each)
not logged in	Open leases, post a delete	Redirect to login	Redirect to /login (HTTP 302)

All 33 requests behaved as the permission table says (Figures 5 and 6 of Activity 3 show the screens).

4. Database level

Check	Result
Roles named in the plan that exist after setup	None. The query for boardtrack% and app_% roles returned 0 rows
Account used by the running app	postgres, a superuser (the README example puts it in DATABASE_URL)
Table owner	postgres for all 8 tables
Database privileges (datacl)	Empty, so PostgreSQL defaults apply (PUBLIC can connect)

5. The plan applied to a copy of the database

To see what the documented plan would do, the sketch in docs/user-roles.md was run unchanged on a separate copy (boardtrack_plain, built from db/boardtrack_full_setup.sql). The live database was not changed.

Test	Expected from the plan	Actual
boardtrack_app reads app_user and logs in with crypt()	Allowed	Allowed
boardtrack_app updates a lease and the trigger changes the room	Allowed	Allowed (rolled back)
boardtrack_app deletes from lease or payment	Needed by the admin Delete button	Denied (permission denied)
boardtrack_app updates app_user.role	Not needed	Allowed (UPDATE 0 rows only because of WHERE false)
boardtrack_app CREATE TABLE, DROP TABLE, CREATE ROLE	Denied	Denied
app_readonly_grp reads password hashes in app_user	Not intended	Allowed
app_readonly_grp inserts	Denied	Denied
boardtrack_admin_grp reads lease	Allowed (full access)	Denied: the sketch gives it no privileges
boardtrack_owner exists	Yes	No, the sketch does not create it

6. Issues and recommendations

#	Finding	Recommendation
1	No database roles exist and the app runs as a superuser. All access control is in application code, so any bug or injection gives full database control. The three application roles share one database account	Create the roles and have the app connect as a non-owner runtime role
2	The sketch gives boardtrack_app no DELETE, so the admin delete buttons would fail	Grant DELETE only on the tables the admin may delete from
3	The sketch lets boardtrack_app update app_user (including role) and lets app_readonly_grp read the password hashes	Grant app_user to a separate login role, with only SELECT on username, role, is_active and password_hash, and no UPDATE
4	boardtrack_admin_grp has no grants and boardtrack_owner is not created	Complete the script and add it to the repository
5	Tenant isolation is done only in the list queries (WHERE tenant_id = …). The	Add row-level security or tenant views

	database has no row-level security, so a new route that forgets the filter would show every tenant's data	
6	No audit trail: there is no audit table or trigger, and the admin can delete payments and leases	Add audit triggers or keep deleted records
7	Account management exists only as SQL on app_user	Add an account screen or script

Good points: the application permission table matched behaviour in every test, tenant lists are correctly limited, and every business rule is in the database.

7. Feedback to owners

Sent on 6 November 2026: findings 1 to 5.

8. Limitations

The database copy tests used the sketch exactly as written, not a corrected design. Application tests used real logins to the running app. The live database was not given any new roles.

AI usage declaration

- Tool: Claude (Anthropic).
- Tasks: interpreting the results of the testing.
- Validation: the commands were run by the group on its own server, and every result in this report comes from the saved output files.